TEAM PROJECT 02

한국·캐나다 OTT

하이브리드 인프라 & 보안 컨설팅

강사 피드백과 실제 PC 환경을 반영한 실행 계획

PC별 독립 구축 · 보안 5건 · OTT/AI · 영상 CDN · 복원

v0.3 PUBLIC TEAM REVIEW / 2026.10.19

유용수 · 윤서영 · 홍은서 · 박진혁 · 유은혜

공개용: 내부 IP·상세 연결값 생략 / 실제 구축·검증 전

PROJECT PLAN

05

PHYSICAL PCs

각 PC 32GB / 교실 LAN 연결

05

SECURITY CASES

담당별 취약 상태·개선·재검증

04

WEEKS + PRESENTATION

10.19~11.13 / 발표 11.16

토폴로지 v1.1 기준 / 팀 검토안

프로젝트 개요·범위·상태

한국·캐나다 OTT 기업을 가정한 하이브리드 인프라 구축 및 모의 보안 컨설팅입니다.

항목	계획 기준	완료를 판단할 결과
목적	정상 서비스 구축 → 취약점 재현 → 개선 → 동일 조건 재검증	5인 모두 자기 영역의 설계·실습·전후 증거를 설명
기간·환경	2026.10.19~11.16 / 평일 09:00~18:00 / 5인 각 PC 1대·RAM32GB	10/19~11/13 실습·검증·자료 / 11/16 발표
범위	본사·서비스·DR·캐나다 4개 업무망, M2 관제는 독립 PC·UTM	실제 분산 배치와 논리 업무 구조를 구분
서비스	OTT 로그인·권한·목록·MP4·실제 한영 자막 + 캐나다 Store 최소 서비스	OTT/CDN·API·사내 VPN·Store의 정상 흐름별 증거
현재 상태	강사 피드백·사용자 수정 반영 v0.3 팀 검토안 / 도면 v1.1	계획 개정과 실습 완료는 별개. IP·VPN·미러·공개 API 검증 전

회사명 StreamBridge는 가칭. 실제 고객사 실적·상용 보안 진단·검증 완료로 표현하지 않습니다.

v0.2에서 달라진 구성

기존 역할·발표일·Issue 번호를 유지하고 물리 환경에 맞춰 배치와 검증 순서를 구체화합니다.

항목	이전 v0.2	이번 v0.3 / 토폴로지 v1.1
물리 배치	본사 M1/M2 중심의 논리적 단일 허브 표현	M1~M3 각 PC의 VyOS+UTM / M2 독립. 교실 GW 교실 GW(팀내 확인값) 사용
망 분리	모든 주요 망 VLAN 기본안	M1만 GNS3 VLAN. M2/M3/M5는 UTM NIC별 독립 VMnet
M1 자산	중간 도면에서 서버·PC 묶음 표현	서버10·직원PC6·관리PC2·기존 스위치10을 개별 복원
AWS·미디어	캐나다 S3 정적 웹 중심 / 영상 경로 미상세	OTT S3(서울 기준안)+CloudFront React/MP4/VTT / 캐나다 Store ALB/EKS/RDS
초기 검증	설계 후 통합 시험 위주	10/20 브리지, 10/23 설치 인터넷·API/미러/공수 판정, 10/28 경로·VPN
일정 정합성	계획서 W2 공격5건 / WBS는 3+2 분산	10/29~30 M1/M2/M4, 11/02 M3/M5. Replica는 TO-BE 11/05 초기 검증

v0.1·v0.2는 이력으로 보존. 이번 계획이 과거의 “모든 망 VLAN”·캐나다 OTT 정적 S3 배치 설명보다 우선합니다.

시나리오를 먼저 정하고 구축·재현·개선

AS-IS는 보안 개선 전 환경, TO-BE는 원인에 맞는 통제를 적용한 개선 후 환경입니다.

단계	수행 내용	다음 단계 진입 조건
1 시나리오 선정	S01~S05 출발지·대상·계정·취약 설정·정상 업무·증거 정의	격리 범위·시험 방법·기대 결과·롤백을 각 담당/검토자 확인
2 AS-IS 구축	PC별 NIC·VMnet·라우팅·인터넷·VPN·기본 OTT 연동	시험 대상 정상 작동·왕복 경로·로그·승인 범위 확보
3 공격·원인 분석	같은 조건을 재현할 수 있도록 입력·시각·결과 기록	5건 실제 전 상태 증거. 도달·인증·권한·차단을 구분
4 컨설팅·TO-BE	영향·원인·개선 권고 후 정책 적용. 정상 기능·롤백 확인	정책 차이·담당·적용 시각·서비스 영향 기록
5 동일 조건 재시험	같은 출발지·계정·대상·횟수/간격으로 보안·정상 기능 시험	전후 비교·근거·실패·미수행·잔여 위험까지 교차 검토

도구 설치·timeout·VPN up만으로 성공 처리하지 않습니다. AS-IS 증거를 확보하기 전에 취약 조건을 제거하지 않습니다.

한 PC로 합치지 않는 5인 분산 구축

각자 VM을 실행한 채 교실 LAN을 통해 연결합니다. 전체 논리도는 물리 PC 경계를 함께 표시합니다.

물리 PC	외부 연결과 경계	내부 서비스·역할
M1 유용수	교실 LAN ↔ VyOS1(K1) ↔ transit T1 ↔ UTM1	GNS3 VLAN / 본사 DMZ·서버·직원·관리·공통 / VPN 허브
M2 윤서영	교실 LAN ↔ VyOS2(K2) ↔ transit T2 ↔ UTM2	SOC [내부 IP] / TEST [내부 IP] / MGMT [내부 IP] / 중앙 관제
M3 홍은서	교실 LAN ↔ VyOS3(K3) ↔ transit T3 ↔ UTM3	DMZ [내부 IP] / APP [내부 IP] / DATA [내부 IP] / TO-BE MGMT [내부 IP]
M4 박진혁	UTM4(K4) 교실 Bridged 직결 제안 / 출구 10/23 결정	Backup [내부 IP] / Replica [내부 IP] / T14·T34 / S3·복원
M5 유은혜	UTM5(K5) 교실 Bridged 직결 제안 / 출구 10/23 결정	운영 [내부 IP] / 콘텐츠 [내부 IP] / 관리 [내부 IP] / T15 / 앱·AWS

K1~K5는 빈 IP를 의미하지 않는 기호. 교실 마스크·추가 IP·VM 브리지 통신 실측 전 주소를 배정하지 않습니다.

고객·직원·관리·백업은 서로 다른 경로

업무상 필요한 통신만 열고, 정상 경로와 시험 경로를 별도로 검증합니다.

흐름	대표 경로	확인 기준
고객 화면·영상	브라우저 → CloudFront → 비공개 S3 / 캐시 미스 시 원본 조회	React·MP4·VTT 응답, 재생·탐색. 고객 VPN 없음
고객 한국 API	브라우저 React → 승인 HTTPS API → VyOS3/UTM3 → Nginx → Spring → DB	실제 공인 진입점·NAT·TLS·CORS 선결 / 사설 IP로 공개 완료 주장 금지
캐나다 사내 업무	콘텐츠 [내부 IP] → T15 → UTM1 → DNS [내부 IP] / WEB [내부 IP]:443	승인 포털·DNS 유지, 직원 DB 직접 접근 제한
관리	승인 관리자 → M2 Bastion [내부 IP] → 허용 관리 대상	M1/M3/M4/M5의 요청·반환 경로와 포트·계정 제한
백업·관제	M4→T34→M3 DB / M4→인터넷→S3 / 각 Agent→M2 Wazuh	세션 시작과 데이터 방향 구분 / 원본·중앙 시각 대조
캐나다 Store	OTT Store 링크 → 캐나다 ALB → EKS React/Spring → Private RDS	OTT DB와 별개 / 관리자 API 권한·모의 주문 / 고객 VPN 없음

교실망에서 인터넷 egress가 가능하다는 사실은 외부 고객이 학교 API로 들어올 수 있다는 뜻이 아닙니다.

주소·게이트웨이·VPN 계약

내부 대역은 토폴로지 v1.1 기준 제안. 교실·VMware·AWS·Pod·Service 대역 중복을 먼저 검사합니다.

구분	주소 기준 / 피어	확정·검증할 내용
교실망	기존 GW 교실 GW(팀내 확인값) / 마스크·K1~K5 미확정	교실 관리자/강사와 추가 IP 확보 / [내부 IP] 중복 배정 금지
VyOS↔UTM transit	T1 [팀내 주소표] / T2 [내부 IP] / T3 [내부 IP] (제안)	각 VyOS [내부 IP] / UTM [내부 IP]. 외부 브리지 NIC와 별도 VMnet
본사·관제	M1 [내부 IP]/[내부 IP]/[내부 IP]/[내부 IP]/[내부 IP]/[내부 IP]/[내부 IP] / M2 [내부 IP]/[내부 IP]/[내부 IP]	모두 192.168.x.0/24 / M1만 VLAN / M2 독립 UTM
서비스·DR·지사	M3 [내부 IP]/[내부 IP]/[내부 IP]/[내부 IP] / M4 [내부 IP]/[내부 IP] / M5 [내부 IP]/[내부 IP]/[내부 IP]	전용 NIC·VMnet 경계와 동일 LAN 호스트 통제 구분
VPN 기본안	T15 UTM5↔UTM1 / T14 UTM4↔UTM1 / T34 UTM4↔UTM3	UTM 피어의 transit 주소까지 VyOS 경유 라우트·NAT 예외 필요
팀 내부 라우팅	M1~M3 각 VyOS/UTM을 경유 / 전 구간을 VPN으로 표기하지 않음	각 목적지·반환·다음 홉 / M2 시험망 [내부 IP] 반환 / M4·M5 허브 경유

사설 WAN을 쓰는 UTM의 기본 차단 옵션·IP forwarding·정적 경로는 제품별 확인. 인터넷 NAT와 팀 내부/VPN NAT 예외를 분리합니다.

기술별 책임과 선정 이유

장비 개수와 기능 개수를 동일시하지 않고, 실제 지원 기능·버전·라이선스를 W1에 확인합니다.

기술	역할	검증·혼동 방지
VyOS / UTM / GNS3	상위 연결·라우팅 / 경계정책·VPN / M1 VLAN access·trunk 실습	UTM 제품·NIC 수 확정. VMnet 번호는 VLAN ID가 아님
vSphere / Docker / K8s	VM 운영 / 이미지 빌드 / Pod 배치·복구	중첩 가상화·RAM32GB 실측. 런타임은 CRI 지원 여부 확인
Wazuh / Suricata	서버 이벤트 수집·경보 / 보이는 패킷 분석	원격 SPAN 자동 수집 불가 / SSH 내용은 서버 auth 로그
Nginx / LB / RBAC	HTTPS API 프록시 / 분산 / 작업 권한	TCP 포트 제한과 K8s 작업 권한은 별도
복제 / 백업 / DR	변경 전달 / 시점 사본 / 업무 복구 절차	복제 지연·백업 해시·실제 DB 복원은 별도 증거
STT / LLM / CDN	음성 인식 / 한영 번역 / React·영상·자막 전달	실제 타임코드·VTT 재생 확인. CloudFront에 직접 파일 업로드하지 않음

선택 확장: WAF, 추가 언어·챗봇, 고급 HA·자동 전환. 결제·DRM·상용 스트리밍 엔진·실시간 더빙은 기본 범위 제외.

담당과 협업 경계

전원이 자기 인프라·취약점 재현·보안 개선·재시험·기술 기록을 수행합니다.

담당	주 책임	협업·검토
M1 유용수	본사 GNS3 VLAN·VyOS1/UTM1·주소/경로 취합·VPN 허브·S01	각 망 담당이 자기 설정 / M2 관리 접근 / 전원 통신 계약
M2 윤서영	독립 VyOS2/UTM2·SOC/TEST/MGMT·Wazuh/센서·Bastion·S02	전원 원본 로그 제공 / M3 현지 센서 / 중앙 수집 총괄
M3 홍은서 · PL	서비스망·vSphere·K8s·MySQL·Nginx·M5 코드 배포·S03	M5 API·DB·AI 통합 / M4 복제·복원 / 기술 의존성 조율
M4 박진혁	백업·Replica·S3·격리 복원·S04	M3 DB 버전·계정·데이터 대조 / M1 VPN / M2 감사
M5 유은혜 · PM	캐나다 UTM5·T15·OTT/AI 및 Store 전체 코드·AWS·S05·일정	M3는 한국 배포·DB 운영 / M1 VPN / M2 로그. 개발 임의 이관 없음

PM의 일정·기록 취합은 기술 검토를 대신하지 않습니다. 주요 변경은 담당·PL·PM·팀 합의를 남깁니다.

M1 본사 장비와 연결을 보존

기존 장비를 하나의 묶음으로 축소하지 않습니다. 동시 실행량은 설계 자산 수와 별도로 관리합니다.

구역	개별 자산·연결	담당 완료 기준
DMZ [내부 IP]	SW-DMZ-CORE→SW-WEB/ SW-PUBLIC→WEB [내부 IP], DNS [내부 IP], SFTP [내부 IP]	GNS3 V110 access / UTM eth1 untagged [내부 IP]
SERVER [내부 IP]	SW-SERVER-CORE→SW-APP/SW-DATA→WAS [내부 IP], DB [내부 IP], Backup [내부 IP], Log [내부 IP], NFS [내부 IP]	GNS3 V120 access / UTM eth2 [내부 IP]. 동일 LAN 호스트 FW·DB 권한
직원·공통	SW-LAN-CORE→SW-DEPT(V130/131/132 각 PC2) 및 SW-COMMON(V150 Samba·DHCP)	UTM eth3 trunk / 각 GW [내부 IP] / DHCP relay [내부 IP]
관리 [내부 IP]	SW-ADMIN→관리PC [내부 IP]/[내부 IP] / UTM eth4 untagged	GNS3 V140 access / M2 Bastion 경유 정상 관리
자산·S01	서버10·직원PC6·관리PC2·스위치10 / M2는 독립망	직원 [내부 IP]→M2 SSH [내부 IP]:22 AS-IS 도달· TO-BE 차단

교실→VyOS1→UTM1 구성을 유지. 전용 eth1/2/4까지 하나의 trunk로 통합하지 않음 / eth5·eth6 미사용.

M2 독립 UTM과 중앙 관제

M1 UTM 아래 SOC 구조를 폐기하고 별도 물리 PC·VyOS2·UTM2에서 관제망을 운영합니다.

구역/작업	구성	완료·증거
UTM NIC4개	WAN transit T2 / SOC [내부 IP] / TEST [내부 IP] / MGMT [내부 IP]	각 LAN 독립 VMnet / VLAN·UTM 하위 통합 스위치 없음
SOC	Wazuh [내부 IP], Suricata 관리 [내부 IP], SSH시험 [내부 IP], 관제PC [내부 IP]/[내부 IP]	Agent 연결·원본 이벤트·시각·출발 IP·서버 서비스 확인
TEST / MGMT	Linux 시험 [내부 IP] / TO-BE Bastion [내부 IP]	AS-IS 관리 NIC는 예약. 일반 시험 PC의 관리 우회 금지
패킷·로그	수집 NIC←지원되는 로컬 미러 / M3 현지 센서 alerts→M2	10/23 미러 기능·source/destination·실제 pcap 가시성 판정
S02	정한 횟수·간격의 SSH 실패→Wazuh 경보·서버 제한	경보와 실제 제한을 따로 시험 / 승인 관리자 로그인 유지

단순 VMnet 연결로 모든 패킷이 보이는 것은 아님. 미러 미확정이면 해당 탐지는 미수행, 원본 Agent 수집과 구분합니다.

M3 한국 서비스 인프라·PL

앱 코드는 M5가 제공하고 M3는 Linux·DB·컨테이너·한국 API 배포와 운영을 담당합니다.

구역	기본 배치	성공 기준
UTM3 / DMZ	VyOS3↔transit T3↔UTM3 / eth1 DMZ VMnet2 / Nginx [내부 IP]	Nginx /api → Worker [내부 IP]/[내부 IP]:30080
APP	eth2 VMnet3 / CP [내부 IP], Worker [내부 IP]/[내부 IP] / Spring·FastAPI Service	실제 클러스터·DB 연결·FastAPI 요청 / Pod·Service CIDR 비중복
DATA / MGMT	eth3 VMnet4 / Primary [내부 IP]·Test DB [내부 IP] / TO-BE eth4 VMnet5 [내부 IP]	NIC별 독립망. ESXi·vCenter·센서 관리IP는 제안값
TO-BE 운영	Nginx A/B VIP [내부 IP] 제안·Spring2Pod 다른 Worker	VIP 인계·readiness / CP·Primary·물리PC 단일 장애점 기록
S03 / 로그	M2 [내부 IP]→K8s [내부 IP]:6443 / M2로 서버·센서 이벤트	도달·401/403과 인증 우회 구분 / 반환 경로·정상 API 유지

React·MP4·VTT는 AWS 원본+CDN. 한국 DMZ에 React 정적 웹서버를 중복 추가하지 않습니다.

M4 백업·Replica·AWS 격리 복원

기존 책임을 유지하고 설치 인터넷 출구·세션 시작 방향·실제 복원 조건을 명확하게 합니다.

항목	계획	증거·인계
경계·출구	UTM4 교실 Bridged(K4) 직접 출구 제안 / 10/23 판정	교실 peer·GW·인터넷 NAT 및 내부/VPN 예외
백업 [내부 IP]	Backup [내부 IP] / 운영PC [내부 IP]/[내부 IP] / S04 [내부 IP] / 독립 가상 L2	시험 파일·서버 권한 / 동일 LAN은 UTM만으로 통제 불가
VPN	T34 UTM3 DB, T14 UTM1 허브를 거쳐 관제·관리	Backup/Replica가 Primary [내부 IP]:3306에 TCP 연결 시작
TO-BE Replica [내부 IP]	별도 NIC/구역 [내부 IP] / 11/03~06 적용·11/05 초기 복제	지연·단절 후 재개 / 수동 승격은 별도 시험 범위
AWS S3·EC2	백업 HTTPS 업로드 → S3 → 격리 Restore EC2	해시·시점·DB 데이터 대조 / SSM·S3 endpoint 또는 egress

운영 Primary를 덮어쓰지 않음. Store RDS는 M4 Replica 대상이 아니며 별도 백업 정책이 필요합니다.

M5 캐나다 인프라·OTT/AI·AWS·PM

캐나다 업무 VPN과 고객 OTT/CDN·Store는 서로 독립된 서비스 흐름입니다.

책임	계획	완료·인계
캐나다망	UTM5 WAN+운영 [내부 IP]+콘텐츠 [내부 IP]+관리 [내부 IP] NIC4개	VLAN·trunk·통합 직원 스위치 없음 / 각 VMnet 분리
T15·S05	콘텐츠 직원의 한국 포털/DNS 협업 / 운영시험PC의 한국 Test DB 접근	S05 [내부 IP]→[내부 IP]:3306 전후 / 정상 포털·DNS 유지
OTT·AI 코드	React·Spring/MySQL 연동·FastAPI/STT·한영 VTT	M3에 버전·스키마·포트·환경변수 이름·실행/롤백 인계
AWS·Store	OTT S3/CloudFront 및 캐나다 ALB/EKS React+Spring/Private RDS	10/23 비용·공수 판정 / 기본 상품·모의 주문 / RDS 백업
PM	WBS·Issue 연결·선행 작업·팀 결정·리스크 관리	기술 증거는 각 담당 확인 / 미확정 항목 담당·기한 관리

코드 업무를 M1/M2/M3/M4에 임의 배정하지 않음. M5 과부하 시 팀이 배치 단순화·지원·범위 변경을 명시적으로 결정합니다.

작업을 연결하는 인계 계약

파일만 전달하지 않고 받는 사람이 실행·연결·복원을 재현하는지 확인합니다.

관계	전달 정보	공동 시험
각 담당 ↔ M1	IP·마스크·NIC·peer·필요 포트·정적/반환 경로·NAT 예외	교실 PC 간 왕복 / 승인·금지 서비스 / VPN 보호 트래픽
M5 → M3	고정 코드/이미지·Java/Python/DB 요구·스키마·샘플·환경 변수 이름	초기화·기동·DB·로그인·자막 / 비밀값은 별도 전달
M3 ↔ M4	DB 버전·엔진·백업/복제 계정·일관성·복원 데이터	실제 복제·S3 사본 복원·표본/건수·앱 조회
M2 ↔ 전원	Agent 포트·원본 로그·시간 기준·센서 관측 위치·경보 조건	원본/중앙 이벤트 대조 / 미러 pcap / 탐지와 차단 별도
전원 ↔ PM·PL	Issue·Notion 근거·오류·막힌 선행 작업·다음 행동	검토 전 In review / 선행 미달 Blocked / 변경 후 일정 갱신

외부 공개용 React·API·Store와 취약한 격리 시험 구역의 비밀정보·계정·접근 정책을 혼용하지 않습니다.

설치용 인터넷과 팀 내부 연결을 먼저 검증

교실 GW 교실 GW(팀내 확인값)은 확인값이지만, 추가 IP·서브넷 마스크·브리지 허용 여부는 실측해야 합니다.

기한/담당	작업	통과 기준·실패 대응
10/20 전원·M1	G0: 실제 PC 주소·마스크·추가 IP 확보 / 두 PC 브리지 VM 시험	VM 간 양방향 통신·패킷 확인. Host-only 같은 이름은 연결 근거 아님
10/21 오전 전원·PL	G1: NIC/VMnet/GNS3·IP·32GB 동시 실행표 검토	UTM GW·서버·시험 PC 구분. 승인된 구역부터 21일 오후 구축
10/23 각 담당	G2: VM→UTM→출구→교실 GW→인터넷	DNS 조회·저장소 HTTP(S)·실제 패키지 다운로드·시간동기화
10/23 M1/M2/M3/M5	G3: 공개 API·센서 미러·AWS 비용/Store 공수 판정	불가 시 대안/미수행 경계·담당·기한 기록, 완료로 추정 금지
10/28 M1+전원	G4: 요청/반환 라우트·VPN·NAT 예외·허용/차단	인터넷 egress와 내부·VPN 통신을 분리 시험

설치 허용은 모든 구역 상시 인터넷 개방이 아님. DB/백업은 필요 목적지·업데이트만, 공격망은 설치 후 외부 접근 제한합니다.

5개 공격은 서로 다른 보안 질문

관리 포트 도달·인증 실패 탐지·파일 권한·VPN 이후 접근 통제를 구분합니다.

ID / 담당	현재 시험 경로	AS-IS → TO-BE 판정
S01 / M1	직원 [내부 IP] → M2 SSH [내부 IP]:22	관리 포트 도달 → 직원 거부 / 승인 Bastion 관리 유지
S02 / M2	Linux [내부 IP] → 같은 SSH [내부 IP]:22	반복 실패 탐지·제한 미흡 → 원본/경보·제한 확인
S03 / M3	M2 [내부 IP] → 각 VyOS/UTM → CP [내부 IP]:6443	불필요한 관리 API 도달 → 시험 IP 차단 / 승인 작업·API 유지
S04 / M4	시험PC [내부 IP] → Backup [내부 IP] / SFTP22 제안	시험 계정의 가짜 파일 읽기 → 읽기 거부 / 승인 복원 유지
S05 / M5	운영 [내부 IP] → T15·M1·M3 → Test DB [내부 IP]:3306	VPN 내부 DB 직접 접근 → 직원 거부 / 포털·DNS·OTT 유지

S03의 이전 DMZ 출발, 이전 UTM2=M3 번호는 이번 개정으로 대체. 운영 DB·인터넷 외부 대상을 공격하지 않습니다.

S01 | 직원이 서버 관리 포트에 도달하는가?

담당 M1 / 대상 SSH 시험 서버는 별도 M2에 있어 실제 PC 간 라우팅이 선행되어야 합니다.

단계	수행	필요 증거·정상 기능
시험 조건	직원 [내부 IP], M2 [내부 IP]:22, 서버 실행 / 시험 IP만 임시 허용	출발/목적·TCP22·허용 규칙·새 연결·시각 기록
AS-IS	TCP/SSH 배너·로그인 화면 도달을 확인	로그인 성공·관리자 권한 취득으로 확대하지 않음
개선	직원 관리 포트 직접 접근 거부 / 승인 관리PC→Bastion→대상	UTM 경계·계정 제한·기존 세션 처리·롤백 기록
재시험	같은 PC의 새 연결 실패·차단 로그 / 승인 관리 접속 성공	사내 WEB443·DNS53 유지. 라우트 오류를 차단으로 오판 금지

일반 직원의 네트워크 접근 범위 문제입니다. 반복 비밀번호 시도는 S02와 구분합니다.

S02 | 반복 SSH 실패를 탐지·제한하는가?

담당 M2 / 네트워크 도달을 허용한 상태에서 인증 실패 이벤트·경보·제한을 비교합니다.

단계	수행	필요 증거·정상 기능
시험 조건	Linux [내부 IP] → SSH [내부 IP] / 가짜 시험 계정·실패 횟수/간격 고정	서버 auth 로그·Wazuh 연결·규칙·관찰 시간 확인
AS-IS	정해둔 소수 반복 실패 / 중앙 경보·제한 상태 기록	경보 없음은 수집·검색·시간 범위를 먼저 확인
개선	수집·임계값 조정 / 서버 인증 제한 또는 Fail2ban 등 별도 구현 제안	Wazuh 경보와 실제 차단을 별도 항목으로 기록
재시험	동일 조건 경보·제한/해제 확인 / 승인 관리자 정상 로그인	원본·중앙 로그의 IP·시각 대조. SSH 암호화 내용을 IDS로 읽었다고 주장 금지

채택 도구·버전·정책은 실제 환경에서 확정. 경보만 발생했다면 “탐지 성공”으로 쓰고 “차단 성공”으로 쓰지 않습니다.

S03 | K8s 관리 API가 과다 노출되어 있는가?

담당 M3 / 현재 출발지는 M2 시험 PC이며 v0.2의 DMZ 출발 설명을 대체합니다.

단계	수행	필요 증거·정상 기능
시험 조건	M2 [내부 IP] → UTM2/VyOS2 → VyOS3/UTM3 → [내부 IP]:6443	실제 CP·포트·원본 로그 / 요청·반환 경로 준비
AS-IS	지정 시험 IP만 임시 허용 후 TCP/TLS 연결 확인	HTTP401/403도 도달 증거 / 인증 우회와 구분
개선	관리 API는 승인 관리 경로만 허용 / K8s RBAC 최소 권한	방화벽은 경로, RBAC은 작업 권한. 적용 전후 별도 확인
재시험	같은 시험 PC 연결 차단·정책 로그 / 승인 API 작업 성공	고객 /api, DB 연동·영상·자막도 정상 확인

별도 ESXi 관리망을 만들어도 K8s API가 자동 이동하지 않음. [내부 IP]:6443의 출발지 제한을 유지합니다.

S04 | 비인가 계정이 백업 파일을 읽는가?

담당 M4 / 동일 [내부 IP] 통신은 UTM을 지나지 않으므로 파일·계정 권한이 핵심입니다.

단계	수행	필요 증거·정상 기능
시험 조건	[내부 IP] → Backup [내부 IP] / SFTP22 + 가짜 백업 파일 제안	비인가 시험 계정과 승인 백업·복원 계정 분리
AS-IS	시험용 과다 권한으로 가짜 파일 다운로드·읽기	경로·소유자·권한·접근 로그 / 운영 데이터 금지
개선	디렉터리·파일·계정 최소 권한 / 필요 시 서버 호스트 FW	암호화는 잘못된 읽기 권한을 대신하지 않음
재시험	같은 시험 계정 읽기 거부 / 승인 계정 읽기·별도 DB 복원 성공	파일 해시와 실제 DB 레코드/건수·앱 조회를 구분

시험 방식은 초기 검토 후 확정. S3 권한 검증을 추가하더라도 운영 버킷 공개·데이터 삭제 실험으로 확대하지 않습니다.

S05 | 캐나다 직원이 한국 DB에 직접 접근하는가?

담당 M5 / VPN으로 암호화해도 업무상 필요하지 않은 DB 직접 접근은 별도로 제한해야 합니다.

단계	수행	필요 증거·정상 기능
시험 조건	[내부 IP] → T15 → UTM1/VyOS1 → VyOS3/UTM3 → Test DB [내부 IP]:3306	운영 Primary [내부 IP] 제외 / 가짜 계정·데이터 / 왕복 라우트
AS-IS	시험 IP·Test DB만 허용, TCP 도달 또는 정한 가짜 데이터 조회	TCP 연결과 DB 로그인·조회 성공을 별도 기록
개선	직원→DB3306 직접 접근 거부 / APP·백업·관제 등 승인 예외 유지	콘텐츠 [내부 IP]→DNS [내부 IP]·WEB [내부 IP]:443 정상 경로 유지
재시험	동일 직원PC·계정의 DB 차단 / 포털·DNS·OTT/API 정상	응답 없음만으로 차단 단정 금지 / 각 경계 정책 로그

T15 up와 S05 성공은 별개. 고객의 CloudFront·Store HTTPS는 회사 VPN을 사용하지 않습니다.

개선 정책과 정상 업무를 함께 확인

각 담당은 자기 영역의 정책·원본 로그·Agent를 구성하고 M2는 중앙 수집과 교차 대조를 총괄합니다.

경계	허용할 목적	차단·검증
직원·관리	승인 사내 포털·DNS / 승인 관리자→Bastion→대상	일반 직원 직접 SSH·관리 API 차단
서비스	공개 HTTPS→Nginx /api→Worker Service→Spring	DB·AI·관리 포트 직접 공개 금지 / TLS·CORS·인증
데이터	Spring·승인 백업/Replica·관리 계정	직원 DB 직접 접근 차단 / DB 관측 출발 IP·GRANT 검증
백업	백업 작업·격리 복원에 필요한 파일·S3 권한	비인가 계정 읽기 거부 / 승인 복원 유지
관제·운영	Agent1514·DNS·NTP·저장소·모델 API 등 목적별 허용	허용 정책·수집 범위·미러 가시성·인터넷 설치 증거 분리

적용 순서·롤백·서비스 영향·정책 차이를 기록. 방화벽·VLAN·VPN·WAF·RBAC·IDS/IPS 역할을 혼동하지 않습니다.

OTT·AI 기능과 코드 인계

짧은 샘플 영상으로 정상 서비스와 인프라·보안·복원 검증의 공통 기준을 만듭니다.

계층	기능	완료 기준
React	로그인·권한별 화면·콘텐츠 목록·MP4 플레이어·언어/자막	브라우저는 CloudFront에서 정적 파일·영상·VTT 수신
Spring / MySQL	인증·인가·콘텐츠/자막 작업 API / 사용자·콘텐츠·URL·상태	DB에 대용량 영상 파일을 넣지 않음 / 오류·권한·초기화 시험
FastAPI / STT·LLM	영상 음성 추출→타임코드 원문→한영 번역→SRT/VTT	30~60초 실제 생성 결과·시간 일치·키 서버 보관·호출 상한
파일·비동기 처리	생성 VTT를 S3에 업로드하고 CDN URL을 메타데이터에 반영	AI 지연·실패가 기본 영상 재생을 막지 않도록 상태·재시도
인계	M5 전체 코드 / M3 한국 런타임·DB·K8s 배포 / 공동 통합	10/28 로컬 → 10/30 배포 기본 기능 → 11/06 실제 AI·CDN 자막

추가 언어·챗봇은 선택. 실제 AI 결과 없이 모의 응답만으로 AI 완료 처리하지 않습니다.

React·영상 CDN과 캐나다 Store 배치

파일은 S3에 업로드하고 CloudFront가 전달합니다. 원본 보호와 사용자별 재생 권한은 별개입니다.

서비스	배치·요청 경로	검증·책임
OTT React·영상·자막	서울 기준안 비공개 S3 app/media/subtitles → CloudFront HTTPS	M5 배포·M3 통합 / 업로드·재생·탐색·VTT·OAC 직접접근 거부
한국 API	React 브라우저→별도 공개 HTTPS 진입점→M3 Nginx/Spring	공인 IP·학교 인바운드·포트포워딩 미확정 / 불가 시 내부 API 별도 시험
캐나다 Store	Route53 store→캐나다 ALB→EKS React/Spring→Private RDS	M5 코드·AWS / Public ALB2AZ·private Worker·SG·NAT/Endpoint·백업
접근 통제	OAC는 S3 원본 읽기 제한 / 로그인 전용은 서명 URL·쿠키 등 추가	S3 private만으로 CloudFront URL이 로그인 전용이라고 주장 금지
운영 선결	10/23 계정·리전·예산·IAM·DNS/TLS·공수·종료 책임 판정	공인 API·Store EKS/RDS 미충족은 실패/미수행 기록, 대안은 팀 결정

도메인 미보유 시 실제 CloudFront/ALB DNS로 시험 범위를 명시. CloudFront는 글로벌 서비스이며 캐나다 내 데이터 처리 보장을 뜻하지 않습니다.

vSphere·Docker·K8s와 부분 이중화

32GB PC 한 대의 자원을 실제로 계산하고, 노드·Pod·물리 호스트의 장애 범위를 구분합니다.

계층	기본 계획	검증·한계
가상화	VMware Workstation / 사용 가능한 vSphere·ESXi/vCenter	중첩 가상화·CPU·메모리·라이선스 W1 확인 / 대체는 팀 기록
Kubernetes	ControlPlane1+Worker2 / 외부 MySQL VM / 내부 FastAPI Service	AS-IS Spring1Pod → TO-BE2Pod 다른 Worker / CNI 정책 지원
Nginx	AS-IS1대 → TO-BE A/B + VIP [내부 IP] 제안	VRRP·Nginx health·VIP 인계·VM L2 조건 시험
장애 시험	Pod 삭제와 Worker 중단을 각각 승인 범위로 수행	요청 성공/실패·복구 시간·정상 기능 기록
한계	단일 CP·DB·UTM·물리PC·교실 상위망은 잔여 단일 장애점	APP2Pod나 VIP만으로 전체 시스템 HA라고 표현하지 않음

VM 수·역할은 설계에 보존하되 동시 실행은 실습 단계별 조절. 자원 부족 시 미구현 기능·시험 한계를 명시합니다.

복제·백업·복원·DR의 검증을 분리

원본 DB 버전·엔진·계정·일관성과 복원 데이터 비교 방법을 M3·M4가 먼저 합의합니다.

시험	기준 일정·수행	증거
준비·최초 백업	10/23 RPO/RTO 목표·측정법 / 10/30 최초 백업·Replica 준비	백업 시작/완료·데이터 시점·파일·해시·원본 설정
TO-BE Replica	11/03~06 적용, 11/05 초기 복제 / 11/10 지연·재개 최종 시험	Replica가 Primary3306 연결 시작 / 실제 변경 반영·지연
첫 격리 복원	11/04 별도 Restore DB 복원·조회	원본 덮어쓰기 금지 / 스키마·표본 값·건수·앱 조회
S3 사본 복원	11/06 업로드/다운로드·복원 / 11/10 최종 대조	IAM·무결성·암호화/키·실제 복원 결과
RPO/RTO	목표는 팀 합의, 실제 장애 시각·복원 데이터 마지막 시점·업무 정상 시각 비교	복원 시간만 측정했다면 복원 소요시간 / 전체 DR과 구분

복제가 잘못된 변경도 전달할 수 있으므로 시점 백업을 별도 유지. Store RDS 보호·복원은 캐나다 AWS 구성으로 따로 검증합니다.

날짜가 있는 4주 실행 일정

기존 WBS의 작업 기간과 Issue 번호를 유지하고 초기 검증·CDN·Store·Replica 시점을 보완했습니다.

기간	팀 공동 목표	완료 기준
W1 10/19~23	강사 수정·시나리오·G0~G3 / 10/21 오후 승인 구역 구축 착수	PC 간 브리지·설치 인터넷·기준선·미확정 담당/기한·API/미러/Store 판정
W2 10/26~28	G4 경로/VPN·로그·K8s / M5 로컬 OTT 최소 기능	왕복 경로·정상/차단 / 실제 로컬 로그인·목록·샘플 재생
10/29~30	M1/M2/M4 AS-IS3건 / M3 기본 배포·CDN MP4 / Store 최소 목표	공격3건 원본 증거·정상 배포 / 미달은 Blocked·지원/범위 결정
W3 11/02~06	11/02 M3/M5 AS-IS2건 / 11/03 개선 / 11/04 AI·복원 / 11/05 Replica	11/06 실제 AI VTT·CDN/API·Store·S3 복원 1차 및 정상 기능
W4 11/09~13	09~10 재공격·장애/복구 / 11 증거 / 12 자료 / 13 리허설	전후 비교5건·정상 회귀·실제 복원·제약·개인 기여
11/16	최종 발표·시연 / 환경 사전 점검	실패 시 대체 증거·담당별 설명 / 이후 자원 정리

최종 발표일 고정. W1 Store 공수 판정, 10/28·30 선행 기능 게이트, W4 신규 기능 제한을 일정 위험 관리에 사용합니다.

완료 판정과 증거 기준

계획·팀 검토·설정 적용·실제 통과를 구분하고 실패와 미수행도 정상적으로 기록합니다.

영역	통과 기준	대표 증거
설계·준비	도면·NIC/IP/VMnet·예산·시나리오·담당/기한 검토	설계 리뷰 기록·미확정 목록 / 실습 완료와 별개
연결·인터넷	PC 간 경로·VPN 보호 통신·DNS·저장소 다운로드·정상/차단	양방향 캡처·라우트/NAT·서비스 응답·패키지 설치 결과
보안5건	동일 조건의 AS-IS/TO-BE + 정상 기능·원본 근거	정책 차이·시각·출발/대상·예상/실제·확인자
OTT/CDN·AI·Store	실제 배포·재생·VTT 생성/표시·API 권한·Store 정상 요청	브라우저 요청·CDN URL·API 로그·생성 파일·DB 결과
복구·인계	실제 복제·별도 DB 복원·데이터 대조·다른 담당의 재현	해시·DB/앱 비교·시간·버전·절차·검토 링크

판정: 통과 / 실패 / 미수행 / 조건부 통과. 조건부에는 제한·영향·후속 담당/기한을 기재합니다.

산출물·형상관리·기록 위치

기존 폴더 구조·Issue 번호·기술서 링크를 보존하고 최신 기준과 과거 이력을 연결합니다.

산출물	공식 위치	관리 기준
계획·WBS	plans/project-plan-v0.3.pdf·md / WBS.md	v0.1/v0.2 보존 / 개정 사유·검토 상태·선행 작업
토폴로지	토폴로지 v1.1은 팀내 공유 / design/architecture.md 안내	12쪽 AS-IS/TO-BE / 실제 값과 달라지면 변경 이력
업무·상태	기존 Issue #1~#38 / Projects #4	WBS=일정, Issue=체크리스트·결과, Projects=Status. 날짜 별도 관리
개발·배포	frontend / backend / ai-service, ERD·Class·API	M5 코드·M3 한국 배포 / 비밀값 제외·릴리스 고정
상세 기술서·최종 보고	각 담당 Notion / 결과·보안 컨설팅 보고 및 시연 자료	명령·설정·오류·캡처·전후 근거 / Issue와 링크

문서 갱신으로 Issue/Projects를 Done 처리하지 않습니다. 매일 진행 결과·Notion 근거·막힌 점·다음 작업을 기록합니다.

담당별 검토·기여·결과 책임

모든 담당이 구축·공격·개선·재시험의 증거를 소유하고 연동 상대가 검토합니다.

담당	제출 결과	교차 검토
M1	전체 장비 상세도·GNS3 포트·주소·라우트·VPN·S01	M2 관리 경로 / 각 망 담당 왕복 통신
M2	독립망·수집기·센서 가시성·경보/제한·Bastion·S02	각 담당 원본 로그 / M1·M3 관리 접근
M3	VMnet·가상화·배포·DB·K8s·장애·S03	M5 서비스·AI / M4 복원·데이터
M4	파일 권한·복제·S3·격리복원·측정·S04	M3 DB/앱 / M2 감사 로그
M5	캐나다 NIC·VPN·S05 / OTT·AI·CDN·Store 코드/AWS / PM 기록	M1 VPN / M3 한국 배포 / M2 로그

팀 전원 공통 설정을 M1·M2·PM 혼자 대신했다고 기록하지 않습니다. 지원·공동 수행·본인 수행을 구분합니다.

위험·병목·범위 조정

일정이 부족하면 실제 증거를 줄이기보다 복잡한 배치와 선택 기능부터 조정합니다.

위험	판정 시점·담당	대응
교실·32GB 자원	10/20~23 / 전원·PL	브리지·고유 IP·중첩 가상화·동시 VM 실측. 승인된 독립 구역부터 구축
M3·M5 집중	10/23 및 10/28·30 / PM·PL·해당자	M5 개발/인프라/Store/PM 시간을 분리. M3에 코드 임의 배정 금지
Store EKS/RDS 추가 공수	10/23 / M5·PL·팀·계정 책임자	10/30 최소 흐름 가능성·비용 판정. 불가 시 단순화·지원·범위 변경을 팀 결정
한국 API 외부공개 불가	10/23 / M1·M3·M5	CDN 공개 재생과 내부 API 실습을 분리 / 대체 공개 배치는 승인 후
미러·탐지 오판	10/23 및 시험 전 / M2·M3	pcap 가시성·원본 로그 확인. timeout·미수집을 보안 성공으로 오판 금지
AWS·모델 비용	생성 전·매일 / 계정·M4·M5	상한·알림·호출 제한·IAM·자원 정리. 크레딧/알림은 자동 과금 차단 아님

핵심5건·OTT/CDN·실제 AI 자막·DB 복원 우선. 추가 언어/챗봇→고급 HA/자동전환→복잡한 배치 순으로 변경 검토합니다.

확정된 사실과 미확정 값을 분리

초기 실습에서 값을 얻고 팀이 검토하면 계획·도면·WBS를 함께 갱신합니다.

항목	현재 상태	담당·기한
환경·강사 변경	각 PC32GB·VMware·교실GW교실 GW(팀내 확인값) / M1~3 독립 VyOS/UTM / M1 GNS3·그 외 NIC 분리	이번 개정에 반영 / 실제 구축 완료는 아님
교실 IP·transit·UTM제품	K1~K5·마스크 미정 / 172.20.1~3/30 및 VMnet 번호 제안	전원·M1·PL / 10/20~21
M4/M5 인터넷 출구	UTM 외부 교실 Bridged 직결 제안	각 담당·M1 / 10/23
공개 API·센서·가상화	공인 인바운드·미러·라이선스·노드 자원 미검증	M1/M2/M3/M5 / 10/23 판정
AWS·Store·AI·복구 목표	실제 예산·계정권한·API모델·도메인·RPO/RTO·시험 횟수 미확정	M3/M4/M5·팀 / 10/23
기술 검토·계획 고정	v0.3 팀 검토안 / 사용자 수정 반영과 팀 전원 기술 승인 구분	전원 / 10/21 기준선·10/23 선결 항목 재검토

설계값을 실제 설정으로 추정하지 않습니다. 완료·승인·미수행은 실제 근거가 있을 때만 갱신합니다.

기술 참고와 문서 상태

공식 문서는 설계·설치 검토의 출발점입니다. 버전·라이선스·요금·모델 지원은 실제 선정 시 재확인합니다.

출처	공식 문서	적용 범위
GNS3	docs.gns3.com/docs/using-gns3/advanced/hubs-and-switches	M1 access·802.1Q / VMware VM 연동은 공식 adding-vmware-vms 문서
VyOS	docs.vyos.io/en/1.5/configexamples/policy-based-ipsec-and-firewall.html	IPsec·NAT 예외 / 실제 버전별 설정 재확인
AWS CloudFront	docs.aws.amazon.com/AmazonCloudFront/latest/DeveloperGuide/private-content-restricting-access-to-s3.html	비공개 S3 원본·OAC·별도 시청자 권한
AWS S3 영상	docs.aws.amazon.com/AmazonS3/latest/userguide/tutorial-s3-cloudfront-route53-video-streaming.html	S3 sample.mp4 업로드·CloudFront URL 재생
Kubernetes / Wazuh	kubernetes.io/docs/reference/access-authn-authz/rbac/ / documentation.wazuh.com	RBAC·NetworkPolicy 지원 / auth 원본·경보·차단 구분

2026.10.19 개정. 이 문서는 구축 전 계획이며 실제 공격·성능·공개 API·복원 성공의 증빙이 아닙니다. GitHub WBS·Issue와 함께 사용합니다.